

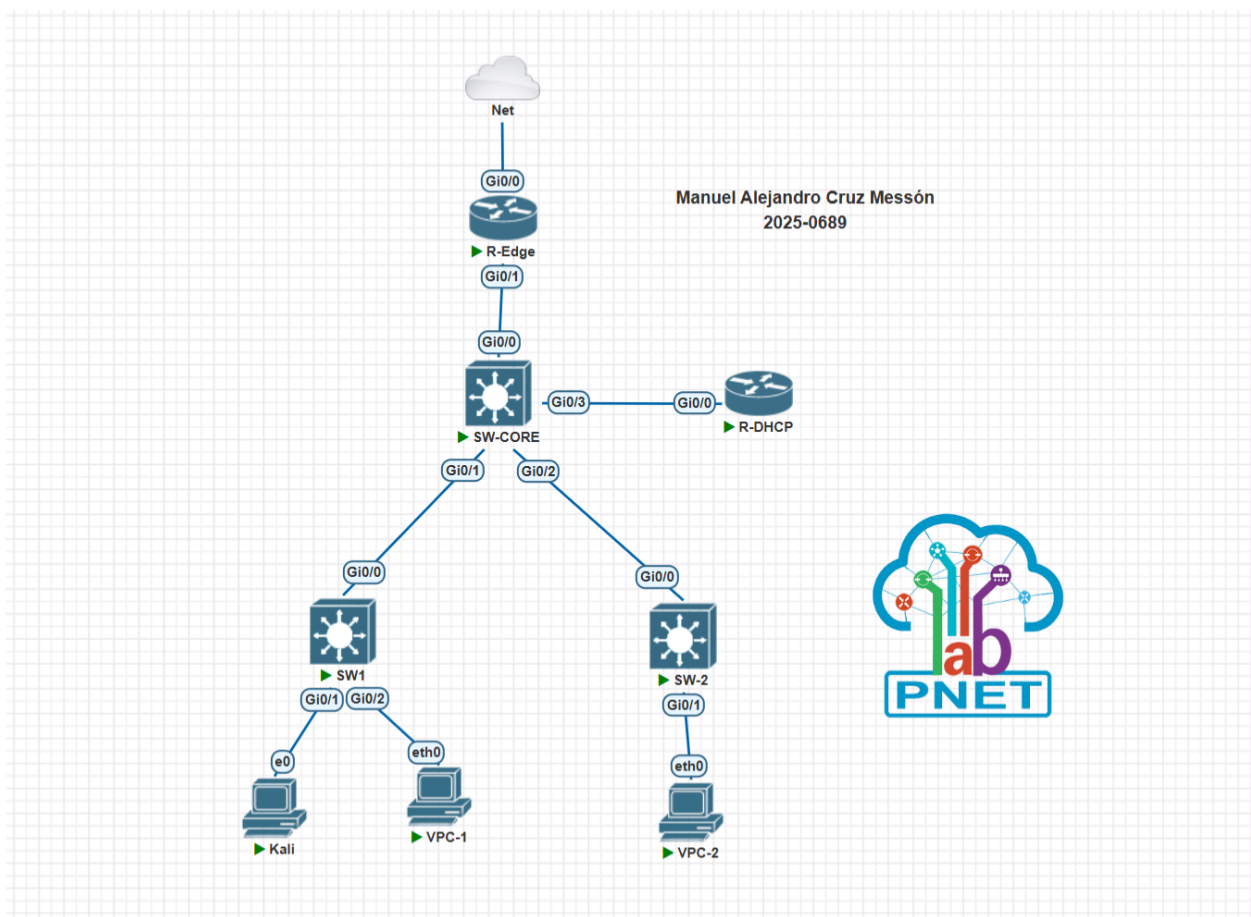
ATAQUE DHCP Spoofing

1. Objetivo del Laboratorio

El objetivo de este laboratorio es **demostrar de forma práctica y controlada la vulnerabilidad intrínseca del protocolo DHCP (Dynamic Host Configuration Protocol) ante la falta de autenticación en redes locales.**

El ejercicio busca ilustrar cómo un atacante puede levantar un servidor DHCP no autorizado (Rogue DHCP Server) para alterar la configuración de red de los dispositivos cliente. Al controlar los parámetros asignados (especialmente la puerta de enlace y los servidores DNS), se sientan las bases para entender las amenazas de interceptación de tráfico y redirección maliciosa.

2 | Topología de la Red



La topología representa una red de laboratorio estructurada bajo una arquitectura jerárquica simple, donde todos los dispositivos internos coexisten en la VLAN 89. La red cuenta con servicios automáticos de asignación de direccionamiento IP (DHCP) administrados por un enrutador dedicado, y salida a redes externas (Internet) a través de un enrutador de borde con traducción de direcciones.

A. Hardware y Dispositivos

La infraestructura física y los nodos que componen la topología se distribuyen según sus roles funcionales en la red:

1. Dispositivos de Enrutamiento (Capa 3):

- R-Edge: Enrutador de borde perimetral encargado de la salida a redes externas.
- R-DHCP: Enrutador dedicado exclusivamente a la administración y distribución de direccionamiento IP dinámico en la red local.

2. Dispositivos de Conmutación (Capa 2):

- SW-CORE: Switch central (Núcleo) que interconecta los enrutadores y distribuye el tráfico hacia los switches de acceso.
- SW-1 y SW-2: Switches de acceso encargados de proveer conectividad directa a los nodos finales.

3. Dispositivos Finales (Hosts):

- Kali: Estación de trabajo orientada del atacante.
- VPC-1 y VPC-2: Computadoras virtuales de escritorio (Virtual PCs) que actúan como usuarios finales de la red.
- Net: Nube que simula el entorno de red externa o Internet.
-

B. Componentes de Software

Entorno lógico y sistemas operativos que corren sobre la infraestructura:

1. **Sistemas Operativos de Red:** Software basado en emulación de Cisco (IOS) para la gestión y ejecución de protocolos de red (CDP, DHCP, NAT, Routing) en los routers y switches.
2. **Sistemas Operativos de Hosts:**
 - Kali Linux instalado en la estación atacante.
 - OS ligero (VPCS) en las terminales de usuario para pruebas de conectividad básica (Ping, Traceroute).

C. Segmentación y Parámetros de Red

Definición del direccionamiento lógico, segmentación LAN y salida a Internet:

- **Segmento de Red Interno:** 192.168.89.0/24 (Máscara de subred 255.255.255.0).
- **VLAN Configurada:** VLAN 89, segmento único donde coexisten de forma nativa todos los dispositivos internos, switches (vía SVI) y routers.
- **Puerta de Enlace (Default Gateway):** 192.168.89.254 (Configurada en la interfaz Gi0/1 de R-Edge). Es el nodo encargado de recibir todo el tráfico interno con destino externo y realizar NAT/PAT para darle salida hacia Internet.

D. Interfaces Utilizadas

Dispositivo Origen	Interfaz Local	Dispositivo Destino	Interfaz Remota
R-Edge	Gi0/0	Net (Nube)	—
	Gi0/1	SW-CORE	Gi0/0
R-DHCP	Gi0/0	SW-CORE	Gi0/3
SW-CORE	Gi0/0	R-Edge	Gi0/1
	Gi0/3	R-DHCP	Gi0/0
	Gi0/1	SW1	Gi0/0
	Gi0/2	SW2	Gi0/0
SW-1	Gi0/0	SW-CORE	Gi0/1
	Gi0/1	Kali	e0
	Gi0/2	VPC-1	eth0
SW-2	Gi0/0	SW-CORE	Gi0/2
	Gi0/1	VPC-2	eth0
Kali	e0	SW1	Gi0/1
VPC-1	eth0	SW1	Gi0/2
VPC-2	eth0	SW2	Gi0/1

3. Objetivo del Script

El script dhcp-spoofing.py es una herramienta automatizada en Python que simula el comportamiento de un servidor DHCP legítimo, compitiendo contra el servidor real de la red. Sus objetivos técnicos específicos son:

4. **Escucha Activa (Sniffing):** Monitorear la red en busca de difusiones legítimas de clientes que intentan unirse a la red o renovar sus credenciales de red.
5. **Suplantación de Servidor (Rogue DHCP):** Responder de manera inmediata a los mensajes DHCP DISCOVER y DHCP REQUEST antes de que el servidor oficial lo haga.
6. **Inyección de Parámetros Modificados:** Asignar a la víctima una dirección IP preconfigurada, pero modificando el **Gateway por defecto** (apuntando al atacante para hacer MitM) y los **Servidores DNS** (para realizar ataques de DNS Spoofing).

4. Parámetros Usados

El script utiliza valores definidos en el diccionario CONFIG que pueden ser sobrescritos desde la línea de comandos mediante argumentos:

- **-i, --interface (Obligatorio):** Especifica la interfaz de red (ej. eth0, wlan0) donde se escucharán y enviarán los paquetes.
- **--server-ip (Opcional):** La dirección IP que usará el script para identificarse como el Servidor DHCP falso.
- **--target-ip (Opcional):** La dirección IP específica que se le forzará a usar al cliente que solicite red.
- **--gateway (Opcional):** La IP de la puerta de enlace que se le entregará a la víctima (por defecto, la IP del atacante).
- **--dns (Opcional):** Lista de servidores DNS que se inyectarán en la configuración del cliente (acepta múltiples valores separados por espacios).

5. Requisitos para Utilizar la Herramienta

Para la ejecución correcta del script en un entorno de pruebas, se requiere:

- **Privilegios de Administración (Root):** Al inyectar y escuchar tráfico en puertos reservados del sistema (67/UDP y 68/UDP) y manipular sockets de bajo nivel, se requiere ejecutar con sudo.
- **Entorno Linux:** El script utiliza dependencias del sistema operativo y validaciones como os.geteuid().
- **Librería Scapy v2.5.0:** Suite esencial para la construcción y deconstrucción de las capas del protocolo de red (Ether / IP / UDP / BOOTP / DHCP).
- **Velocidad en la Red (Condición de Carrera):** El protocolo DHCP responde al que llegue primero. Para que el ataque tenga éxito en un laboratorio, el servidor falso debe responder más rápido que el servidor DHCP real de la red.

6. Documentación del Funcionamiento del Script

El funcionamiento del script emula de forma maliciosa las fases del proceso de asignación de direcciones IP, conocido tradicionalmente como el proceso **DORA** (Discover, Offer, Request, Acknowledge).

Fase 1: Inicialización y Captura

El script arranca en la función `start_spoofing()`, la cual levanta la función `sniff()` de Scapy aplicando un filtro BPF estricto: `"udp and (port 67 or port 68)"`. Esto asegura que el script ignore todo el tráfico de la red excepto los paquetes de control DHCP. Cada paquete capturado es redirigido a la función evaluadora `handle_dhcp_packet()`.

Fase 2: Procesamiento del Mensaje Discover (D de DORA)

Cuando un cliente se conecta a la red, envía un paquete DHCP DISCOVER (Mensaje tipo 1) buscando un servidor.

2. El script detecta el paquete, extrae el identificador de transacción único (xid) del protocolo BOOTP y la dirección física del cliente (`client_mac`).
3. Invoca la función `create_dhcp_offer()`, la cual ensambla un paquete de respuesta DHCP OFFER.
4. En este paquete, el script define el campo `yiaddr` (Your IP Address) con la dirección IP que quiere imponerle a la víctima (`CONFIG['target_ip']`). Envía el paquete usando `sendp()` a nivel de Capa 2.

Fase 3: Procesamiento del Mensaje Request (R de DORA)

El cliente, al recibir la oferta (asumiendo que la del script llegó antes que la del servidor real), envía un DHCP REQUEST (Mensaje tipo 3) confirmando que desea aceptar esa dirección IP.

3. El callback del script detecta el mensaje tipo 3 y extrae el parámetro `server_id` para validar si el cliente lo eligió a él.
4. Si el cliente responde afirmativamente, se invoca la función `create_dhcp_ack()`.

Fase 4: Confirmación Inyectada (A de DORA)

La función `create_dhcp_ack()` genera el paquete final DHCP ACK (Acuse de recibo). Es en este punto donde se inyectan las opciones DHCP maliciosas en una estructura de lista de tuplas:

- Se añade la máscara de subred (`subnet_mask`).
- Se inyecta la opción 'router', asignando el gateway controlado por el atacante.
- Se añade la opción 'name_server', configurando los DNS maliciosos.
- Tras enviar este paquete, el cliente configura su interfaz de red con los datos falsos, quedando bajo el control del flujo de datos del atacante.

6. Documentación de Contra-medidas

Para mitigar y prevenir el despliegue de servidores DHCP falsos como el que ejecuta este script, se deben aplicar las siguientes defensas a nivel de infraestructura:

A. DHCP Snooping (La defensa más efectiva a nivel de Capa 2)

Es una característica de seguridad implementada en los switches de red. Consiste en clasificar los puertos del switch en dos categorías:

- **Puertos Confiables (Trusted):** Puertos donde se sabe con certeza que está conectado el servidor DHCP legítimo de la empresa o un enlace troncal.
- **Puertos No Confiables (Untrusted):** Puertos donde se conectan los usuarios finales o dispositivos desconocidos.

El switch analiza el tráfico DHCP en los puertos "No Confiables". Si detecta que desde uno de estos puertos se intenta enviar un paquete de respuesta DHCP (como el DHCP OFFER o DHCP ACK que genera este script), el switch **bloquea el paquete inmediatamente** y descarta la comunicación, neutralizando el ataque por completo.

B. Seguridad de Puertos (Port Security)

Dado que muchos ataques de DHCP Spoofing van acompañados de un ataque previo de agotamiento de IPs (DHCP Starvation) mediante la creación de direcciones MAC aleatorias para consumir el pool legítimo, limitar la cantidad de direcciones MAC permitidas por puerto en el switch previene que un atacante sature el servidor real para forzar el uso del servidor falso.

C. Implementación de IPv6 con Guardias de Red

En redes modernas que operan bajo IPv6, el equivalente a este ataque se realiza mediante falsos anuncios de enrutador (Router Advertisements). La contramedida equivalente a nivel de switch se denomina **RA Guard** (Router Advertisement Guard), la cual bloquea anuncios de enrutamiento no autorizados en puertos de clientes.